

Policy-based Role and Access Modeling

Noha Ayman¹, Mariam Kiryakos², Caroline Sabty¹, Alia El Bolock¹, Slim Abdennadher¹

¹ Informatics and Computer Science, German International University, Cairo, Egypt

² Swansea University, Swansea, Wales, United Kingdom

Abstract — In this paper, we present an approach based on Attribute Based Access Control (ABAC) and Risk Adaptive Access Control (RAdAC) to improve the reliability of the risk assessment and authorization process. The model has been designed to adapt to the complex and ever-changing nature of modern campus networks by incorporating location information. This added layer of risk assessment enhances the ABAC model by adding a level of authorization to it.

Keywords — *Attribute Based Access Control (ABAC); Risk Adaptive Access Control (RAdAC); policy*

I. INTRODUCTION

With the ongoing improvements to IAM (Identity and Access Management) tools, there remain significant challenges in mitigating identity theft. According to report, [1] Traditional authentication is not enough to protect shared resources as it has been reported that attackers bypassed two-factor authentication protections offered by services such as Gmail and Yahoo Mail. Also, DBIR [2] provided insights into the current threat landscape, and effective security practises. The findings include: weak passwords are a major vulnerability and social engineering is a major factor in successful attacks. The DBIR emphasises the need for strong security practises, including the importance of regularly reviewing and updating security measures to keep pace with evolving threats. Access control enforces access to information, data, services, and systems, as well as physical locations according to security policies that must be formalized, and enforced by the PEP Policy Enforcement Point, which gets permission from the resource's owner. As a result, the owner will attempt to manage the risks associated with access [3].

Access control encompasses authentication, authorization, and accountability (AAA). Authentication verifies a user's identity, authorization determine their access permissions, and accountability holds users responsible for their actions. The document owner approves access only for trusted users. Thus access control uses the following terms:

- Subject - to refer to the process being executed for a single user or an organization, which requests access to the object.
- Object - refers to the entity, file, or even resource to be accessed by the subject.

Identify applicable sponsor/s here. If no sponsors, delete this footnote.

- PDP – Policy Decision Point which validates access requests and provides attributes against the access policy.
- PEP – Policy Enforcement Point which is an authority that will only let an access requester connect to the access supplier if the Policy Decision Point allows it.

Access control has two main categories: Discretionary Access Control (DAC) and Mandatory Access Control (MAC). DAC allows the resource owner to control who can access the resource and at what level of access. In contrast, MAC enforces access control policies based on the resource's sensitivity and the user's clearance level. While early research primarily focused on preventing unauthorized access to classified information, modern applications have extended these policies to commercial settings. Additionally, some studies have explored approaches to decentralised granular entitlements [4], such as Attribute Based and Risk Adaptive Access Control (RAdAC).

The basic concept of ABAC is to allow or deny an authentication request based on some attributes associated with subject, resource, and context. The user requests access then the model compares the attributes to the stored security policies. In general, the security rule of the ABAC model is expressed with the decision (allow or deny), operations (read, write, print, etc.), and the attributes of the subject, object, and environmental conditions. The process of creating a policy for implementing ABAC is known as policy engineering. Policy engineering can be carried out in two ways - top-down and bottom-up; bottom-up policy engineering is also termed as policy mining [5]. Top-down policy engineering framework for ABAC which aims to automatically extract policies from unrestricted natural language documents [6].

While Risk-Adaptable Access Control depends on allocating dynamic risk assignment to the requests based on the risk associated with granting access to a resource [7]. According to the model proposed in [8] RAdAC has three main components:

- Risk Engine: Responsible for generating a risk score based on some information such as user behavior, system logs, and threat intelligence feeds.
- Policy Engine: Associate the access control policy according to the risk information collected.

- Enforcement Engine: Enforce the access control decisions made by the policy engine.

Our proposed model in this paper aims to add a risk assessment authorization to the ABAC which is based on RAdAC. To enhance the authentication process and determine the privilege based on it, Also to be able to determine the risk. The paper's major contributions are as follows:

- How to authenticate the users by bringing network factors on campus
- Policy generation and authorization attributes to detect the role.
- User activity risk assessment.

II. RELATED WORK

In [1], they proposed a risk-based dynamic identity authentication method based on the UCON model to address the shortcomings of identity authentication technology in practical applications, such as continuity and mutability. The proposed method considers a user's access rights based on the degree of risk, except in the case of password authentication. In [9], they proposed a dynamic SoD capability for real-time access control decision-making and policy enforcement, improving on existing access control models by granting users access rights dynamically. The model was implemented using the Balana policy engine and demonstrated its applicability to a real industrial case from a financial institution, showing scalability and meeting the requirements of dynamic access control characteristics. Also, in [10], researchers proposed a framework for estimating risk based on threat and impact scores. The framework includes four threat assessment approaches based on object sensitivity, subject trustworthiness, and the difference between them. Each approach yields a different threat ordering and has specific properties that must be met. Formulae for estimating the threat of subject-object accesses within each approach were also proposed.

The researchers in [5] propose a method to identify anomalies in Attribute-Based Access Control (ABAC) policies by clustering policy rules based on priority-level and similarity, and focusing on each cluster instead of detecting anomalies across all rules.

III. METHODOLOGY

In this section, a hybrid model of ABAC and RAdAC is proposed. The model is enhanced to provide a reliable process of risk assessment and authorization that locates the network on campus to adapt to the complex and changeable characteristics of a modern network, so that the PEP (policy enforcement point) depends on the risk factors. To achieve the model goal, the program consists of three phases, which will be discussed accordingly in the following sections, knowing that the second and third phases are for risk assessment. The phases are: Policy Initialization, White Listing, and Access Logger.

A. Policy Initialization

Security policy is an elementary expression in ABAC; it is a set of rules established for the protection of objects in an organisation. Policies add an advantage to the approach as the decision to allow or deny is based on them. In this model, the first phase is to collect the security policies from the admin clients, where each security policy contains policy name, subject, object, action, and context attributes. We also added a new attribute, a priority attribute, to give the subjects admin rights (the admin subjects are those who are allowed to add a new policy or remove an existing one).

The operations that can be done among the policies are: create a policy, push a policy, and remove the policy from the database. Also, explicit typecasting is added to compare the policy attributes with the request attributes.

B. White-Listing

Whitelisting is a cyber-security strategy that gives certain clients, i.e., devices, specific access given by the admins in advance to prevent any malicious access to the organisation or the network. Whitelisting is the second phase of the system and the first step in the risk authorization assessment. This phase aims to bring the network authentication on campus and limit access to legitimate users. In this phase, the server is given a white list that contains the following information about each device allowed access: IP addresses, host names, and physical regions. Each time the client sends a connection request to the server, a payload will be sent to the server with the client's network information in order to be compared with the white access list.

C. Access Logger

An access logger is a file that records all the client activity and access to resources; mainly, it stores the timestamp that the event took place in, the IP address and host-name of the client, the event, and some extra information. There are three main types of access logger files, which are:

- 1) Activity logs: which record all the client access events during an active session such as visiting URLs and accessing files.
- 2) Server access logs: User connections and resource requests are stored in this file. These logs, unlike activity logs, do not contain detailed information about what the user did. Server access log examples include Linux last log and Windows security log.
- 3) Error logs: Contain diagnostic information about vulnerabilities found during client sessions. These logs are useful for debugging application and system issues.

In this phase, the activity log is used so that the client access request is stored in order to detect any malicious activity or any scripts that the client may send to the

server. This phase aims to apply the second risk assessment process after whitelisting by detecting any identity theft that may take place by recording the last time a client asked for access and from which region, and comparing the timestamp with the recent access request. If the region is changed within an unreasonable interval of time, this will be considered a risk. In addition, the logger file stores the inputs the client sends as access request attributes, and by analysing them, the server can detect if the client entered any scripts that may cause malware attacks.

D. Implementation

The model workflow is as follows: First, the server is connected to MongoDB where the security policies are stored. Thus the security policies are stored as JSON objects, A security policy sample is shown below:

```
{
  "$oid": "63bfb2d9134c50ff8cadf9b4",
  "_name": "policy_name",
  "_subject": "subject_ID",
  "_object": "object_ID",
  "_action": "action_ID",
  "_context": "context_ID",
  "_priority": {"$numberInt": "0"}
}
```

Also, the server is provided with the whitelist, which is stored in a CSV file. Once the client connects to the server, the client sends a payload including the risk factors, which are IP address, host name, and physical location. This payload is a JSON object that contains the IP address, host-name, and country. An example of the payload is generated using requests library and can be shown as follows:

```
[SERVER] Payload recieved --> b' {
  "ip": "192.168.56.1",
  "hostname": "DESKTOP-3SJ31US",
  "country": "Egypt"
}'
```

The communication over the network between the client and server is applied using is socket programming. After the server receives the JSON payload, it compares the payload's attributes with each element in the CSV file to check if this client is whitelisted or not. So that the whitelisting is based on zero trust security model which can be defined in [11] as the concept of "never trust, always verify." In which all access requests are treated as potentially untrusted. Whitelisting is a core component of the Zero Trust model.

If the client is whitelisted, the server checks its access log file for any suspicious behaviour. In the event that the client is white-listed and not blocked by the server due to any malicious activity, Then the server will ask the client for the access request attributes: subject, object,

and context after checking the access logger timestamp variation.

Let's consider a use case for the model in a telecommunications organisation:

Scenario:

1) Attributes:

- Role: Admin, Employee, Security Engineer.
- Clearance Level: Low, Medium, High (indicating the sensitivity of information they can access).
- Object: web access, app access, physical drive access.

2) Risk Factors:

- IP address
- Host-name
- Physical Location

3) Security Policies:

- Admins have IP ranges starting from 10.220.x.x with host-names starting with ITXXXXXX and physical locations in Egypt.
- Employees have IP ranges starting from 10.230.x.x with host-names starting with VNXXXXXX and physical locations in Egypt.
- Security engineers have IP ranges starting from 10.240.x.x with host-names starting with SCXXXXXX and physical locations in India.

4) Access Design:

- If any of the admins, employees or security engineers requested an access it will consider the risk factors then go to the security policies then checks if he access request is accepted or denied.

Thus, the server is always listening to any connection, but it will receive access requests only from white-listed clients. In other words, the server will not terminate a connection, but it will ignore it in case of risk (only the client can terminate the connection from its side). To handle multiple clients, a multi-threading approach is used so that each client connection is held on a thread, which is a sequence of such instructions that can be executed independently of other code. Each connection between the client and the server is referred to as a thread, and each thread defines its execution path. Multi-threading can be used where the client and the server are on the same network. The decision is made based on comparing the access request attributes given by the client to the stored security policies after authorising the client based on the risk factors. Accordingly, the model achieved 3 main terminologies in access control which are AAA: Authentication, Authorization, and Accountability.

- Authentication: The process of proving that the client with a digital identity is requesting access by

checking its IP, host-name, and region (white-listing phase).

- Authorization: Is the process of determining a user's rights to access functionality according to the security policy provided to the server.
- Accountability: A client's obligation to accept the consequences of their actions, whether positive or negative according to the access logger file tracker.

Thus the system design can be shown in the following figure.

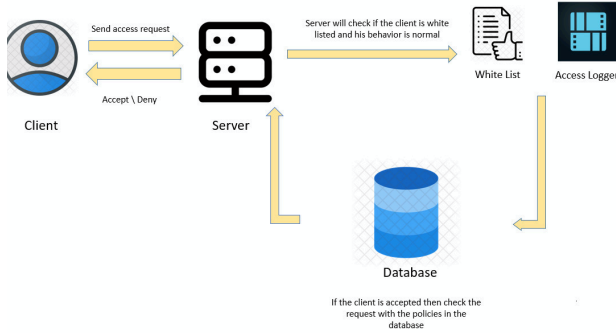


Figure 1. System Design

IV. EVALUATION

In this section, we will examine our project's security and performance. First, we will employ an IP spoofing attack, which will try to impersonate the user. Then comes the replay attacks, which explain how the system tracks user activity, and finally the discussion of security and performance of the proposed model.

A. IP Spoofing Attack

IP spoofing is a malicious attack in which the threat actor conceals the true source of IP packets in order to make it difficult to determine where they originated. The attacker generates packets by changing the source IP address in order to impersonate another computer system, conceal the sender's identity, or both. The most common IP spoofing situation is when the attacker can spoof a fake IP and connect to the server. Or the attacker intercepts the network, steals one of the white-listed users' IPs, and connects to the server as a legitimate user. In this case, only the IP address will match. In both cases, the attacker will still not be able to trigger the authentication process, which depends on the three risk factors (IP address, host name, and physical location) and the timestamp of last access to achieve security in depth. Accordingly, if the attacker spoofed the IP, it will now be possible to revoke the host-name and the physical location assigned to this machine. In this scenario, a connection is made to the server, but the server accepts the connection without actively listening to it or allocating resources for sharing.

B. Replay Attack

The replay attack is an attempt to produce an illegal effect or acquire unauthorised access that involves intercepting sent authentication or access control information and retransmitting it. In this situation, the client is on the network and makes an access request to the server during the authentication step (checking that the client is white-listed). The access request message is intercepted and sent again by an attacker. The timestamp can be utilised to verify that the right requests are received from the client. If the timestamp is mismatched at the user's end owing to an incomplete or malformed request. It can also be utilized to fend off replay attacks. ΔT is the longest possible transfer delay period. When $|T - T^*|$ exceeds will ignore the message where T is the timestamp of the first sent access request message and T^* is the timestamp of the second access request message. The timestamp can also be used when the user receives the authentication result to ensure security. If the message is resent, the timestamp verification will fail, and the server will reject the message. As a result, the proposed model can effectively protect against replay attacks.

C. Discussion

The user's level of authority is no longer fixed but rather adaptable in accordance with their behaviour, which poses potential risks. The authentication of the user is not reliant on passwords but instead on the user's network (IP address), device (host name), and location. This approach introduces dynamic allocation of authentication, making the user's identity verification both consistent and subject to change. The authentication step in the proposed model was chosen because it brings the risk assessment on. Then moving forward to the authorization step, which depends on the security policy attributes and their matching with the access request, and finally the accountability step, which is achieved by implementing the logger file to be able to track the user activity, Although the whitelisting approach provides a high level of security for the system, it's not a scalable solution. In large systems, whitelisting can be used with clustering algorithms in order to provide higher scalability. Also, access logging has several drawbacks, such as storage overwriting, which can be done as an attack on the system. The storage overwriting may take place when the user sends a lot of access requests that extend the access logger file size.

V. CONCLUSION

Access management is a complex task that necessitates precise identity data, policy enforcement tools aligned with risk tolerance, accurate corporate rule representation, and comprehensive awareness of the present environment and contextual factors.

This work aims to propose an access modeling model which includes a risk assessment layer added to the most common access modeling approach which is ABAC. also

to achieve the 3 main terminologies in access control which are AAA.

Considering the daily operations performed, the authentication process has to be dynamic. However, Access Control through the use of ACLs and RBACs is largely static; thus, models can learn how to construct the authority of the clients by knowing their identity and clustering the common identities. In other words, the models can be trained to construct the datasets of organizations. What will still be challenging is calculating the risk factors. Also, the access logger file although it's expensive in execution it can provide excessive information about the user activity which can be trained to recognize the malicious activity.

REFERENCES

- [1] J. Liu, R. Liu, and Y. Lai, "Risk-based dynamic identity authentication method based on the ucon model," *Security and Communication Networks*, vol. 2022, 2022.
- [2] Verizon, "2021 data breach investigations report," 2021.
- [3] A. Koot, "Introduction to access control (v3)," *IDPro Body of Knowledge*, vol. 1, no. 6, 2020.
- [4] A. Colantonio, R. Di Pietro, A. Ocello, and N. V. Verde, "Taming role mining complexity in rbac," *Computers & Security*, vol. 29, no. 5, pp. 548–564, 2010.
- [5] K. Vijayalakshmi and V. Jayalakshmi, "A priority-based approach for detection of anomalies in abac policies using clustering technique," in *2020 Fourth International Conference on Computing Methodologies and Communication (ICCMC)*. IEEE, 2020, pp. 897–903.
- [6] M. Narouei, H. Khanpour, H. Takabi, N. Parde, and R. Nielsen, "Towards a top-down policy engineering framework for attribute-based access control," in *proceedings of the 22nd ACM on Symposium on Access Control Models and Technologies*, 2017, pp. 103–114.
- [7] R. McGraw, "Risk-adaptable access control (radac)," in *Privilege (Access) Management Workshop. NIST–National Institute of Standards and Technology–Information Technology Laboratory*, vol. 25, 2009, pp. 55–58.
- [8] S. Kandala and Y. Xu, "A risk-adaptive access control architecture for cloud computing systems," *Future Generation Computer Systems*, vol. 63, pp. 69–81, 2016.
- [9] M. Uddin, S. Islam, and A. Al-Nemrat, "A dynamic access control model using authorising workflow and task-role-based access control," *Ieee Access*, vol. 7, pp. 166 676–166 689, 2019.
- [10] H. Khambhammettu, S. Boulares, K. Adi, and L. Logrippo, "A framework for risk assessment in access control systems," *computers & security*, vol. 39, pp. 86–103, 2013.
- [11] V. Stafford, "Zero trust architecture," *NIST special publication*, vol. 800, p. 207, 2020.